

Information Security for Southern Cross NZ: Threats, Impacts, and Mitigation Strategies

1. Introduction

In today's age, Information Security (InfoSec) plays a vital role in the success of organizations, including insurance organizations. InfoSec can be defined as the protection of information, a valuable asset, from possible harm resulting from various threats and vulnerabilities throughout its entire lifecycle, including creation, processing, storage, transmission, and disposal (Ključnikov et al., 2019). It is a critical component of general security across national, sectoral, corporate, and personal levels (Lehenchuk et al., 2022).

In the insurance sector, Information Security (InfoSec) is a complex, double-sided issue: insurance companies must maintain robust internal security to protect the vast amounts of sensitive data they hold, while simultaneously acting as de facto regulators that influence the information security standards of the organizations they insure. Insurance companies are prime targets for cyberattacks because they often retain even more personal and sensitive data than banks, including health records, financial details, and behavior patterns (Sullivan & Nurse, 2021).

Southern Cross, the leader in providing health insurance to New Zealanders. Southern Cross has different cashflow or services such as pet insurance, travel insurance, health insurance, and life (Southern Cross Healthcare). Successful attacks on insurers can cause extensive social impacts, potentially affecting pension funds and health coverage, while leading to massive financial losses and reputational damage (Celestin & Vanitha, 2022).

This report will critically analyze the information security (InfoSec) for Southern Cross. Part two will discuss in detail the three threats/risks for Southern Cross in regard to InfoSec. Part three will discuss the mitigation and prevention strategies for the said risks and threats. And Part four will close with Summary and Conclusion.

2. Security Requirements

2.1 MFA and SETA for Ransomware Mitigation

Over the past several years, ransomware has shifted from opportunistic attacks to a highly specialized and professionalized criminal enterprise. A significant part of this growth is the "Ransomware as a Service" (RaaS) business model, where developers lease their malware to "affiliates" who execute the attacks in exchange for a share of the profits (Mott et al., 2023). Common methods for initial infection include phishing emails, exploiting vulnerabilities in internet-facing infrastructure, and compromised remote access services like Remote Desktop Protocol (MacColl et al., 2023). For Southern Cross, this is crucial as they could attack every single employee, and it just needs one to be penetrated.

In May 2021, AXA, one of the largest global insurers (AXA), was attacked by ransomware in their operations branches in Thailand, Malaysia, and Philippines (Mott et al., 2023). The attack was carried out by the Avaddon ransomware group. The group employed a "double extortion" scheme, which involved not only encrypting AXA's files to disrupt operations but also exfiltrating sensitive data beforehand. The hackers successfully stole critical customer documents, which included highly sensitive medical records. To increase pressure on AXA to pay the ransom, the attackers uploaded samples of the stolen data to the public domain (Enjam, 2020).

Ransomware is a sophisticated form of malware that encrypts critical data and demands a ransom for the decryption key, often threatening to destroy or publicly release the information if demands are not met (Alharbi, 2020). To combat this growing threat, Southern Cross must adopt a holistic defense strategy involving technical, organizational, and procedural safeguards.

Implementing **Multifactor Authentication (MFA)** is highly effective at blocking unauthorized access, as stolen credentials alone are insufficient for network entry (Rodrigues et al., 2024). However, MFA can negatively affect system usability and introduces costs for hardware-based authenticators (Saleem & Naveed, 2020).

Security Education, Training, and Awareness (SETA) overcomes the "human firewall" problem by teaching staff and employees to recognize phishing, the primary delivery system for ransomware (Bhadouria, 2022). However, humans remain the weakest link; 52% of breaches are still attributed to human error regardless of training (Rodrigues et al., 2024).

2.2 Encryption for Data Breaches and Unauthorized Access

The insurance industry is a high-value target due to the sensitive health and financial data it maintains (Celestin & Vanitha, 2022). This makes Southern Cross a high-value target of data breaches and unauthorized access.

Data breach can be defined as the unauthorized or unintentional disclosure of sensitive and confidential information by an organization (Wang et al., 2019). This typically results in the loss or exposure of Personally Identifiable Information (PII), such as Social Security numbers (SSN), credit card information, dates of birth, and medical records. Data breaches can be intentional, such as those caused by hacking or theft, or accidental, resulting from human error or system glitches (Alharbi, 2020).

On the other hand, unauthorized access is a form of security violation where individuals gain entry to a computing system, device, or network without permission (Raghupathi et al., 2023). It is frequently categorized as an internal threat when it involves an insider, such as an employee or contractor, who misuses their privileges to view or disclose data (Seh et al., 2020). It can also occur externally if an attacker steals authentication credentials to bypass security and access sensitive files (Nemec Zlatolas et al., 2024).

The Anthem Inc. data breach disclosed in February 2015 is recognized as the largest healthcare data breach in history, exposing the records of approximately 78.8 million individuals (Shankar & Mohammed, 2020). Investigation pointed to a state-sponsored Chinese cyber espionage group known as "Deep Panda" (also referred to as "Black Vine") (Saleem & Naveed, 2020). The attack began with spear-phishing emails targeting employees of Anthem's subsidiary, Amerigroup. The attackers registered a deceptive domain, we11point.com (mimicking Anthem's former name, Wellpoint Inc.), to host a phishing site that tricked users into downloading malware.

Two primary malware families were identified: Sakula, a remote access trojan that masqueraded as legitimate VPN software to gain entry, and Mivast, which was used for credential dumping and running remote commands (Saleem & Naveed, 2020). The

data was stored in an unencrypted data warehouse. While no credit card numbers or actual medical records were believed to have been stolen, the Personally Identifiable Information (PII) taken was highly sensitive, including Social Security Numbers, Medical IDs, Birthdate and home addresses, Detailed employment & income data, etc. (Shankar & Mohammed, 2020). Anthem agreed to a \$115 million settlement to resolve civil class lawsuits, which at the time was a record for a data breach. Additionally, the company paid \$16 million to the Office for Civil Rights (OCR) for potential HIPAA violations (Hossain & Hong, 2020).

Southern Cross must adopt a multidimensional defense strategy to safeguard sensitive information, as security is not solely a technical problem but involves technical, organizational, and policy-driven practice (Tao et al., 2019). **Encryption** of data at rest and in transit ensures that even if data is exfiltrated, it remains unreadable without the decryption key (Alharbi, 2020). Encryption protects confidentiality even if data is stolen. However, it does not protect privacy from the server itself, it is irrelevant if administrative credentials with high privileges are stolen (Sharma et al., 2020).

Intrusion Detection and Prevention Systems are good as these monitors endpoints and network traffic for policy violations or suspicious activity, raising alerts or blocking malicious attempts (Saleem & Naveed, 2020). These detect and blocks intrusions in real-time. However, high false-alarm rates can lead security teams to ignore critical warnings (Saleem & Naveed, 2020).

2.3 Machine Learning, Network Segmentation & Principle of Least Privilege for Mitigation of Phishing and Social Engineering Attack

The insurance industry is a high-value target for phishing and social engineering because it manages vast repositories of Personally Identifiable Information (PII), medical records, and financial data (Enjam, 2020). For Southern Cross, they should be wary of phishing and social engineering since most of their data are composed of PII.

Social engineering is a non-technical attack strategy that relies on the psychological manipulation and deception of individuals to gain unauthorized access to systems, sensitive information, or confidential data (Waelchli & Walter, 2025). Often described as "human hacking," it exploits inherent human vulnerabilities such as trust,

curiosity, fear, and the tendency to obey authority rather than targeting technical software deficiencies (Naz et al., 2024). These attacks typically follow a four-step cycle: information gathering, relationship building (gaining trust), exploitation, and execution (Yu et al., 2024).

Phishing is the most prevalent form of social engineering. It involves sending fraudulent communications, typically emails, text messages, or phone calls, that impersonate a trustworthy entity to trick recipients into revealing credentials, financial details, or downloading malware (Olaniyan, 2024). Common variations include Spear Phishing, Whaling, Vishing & Smishing, Business Email Compromise (Akeiber, 2025; Kheruddin et al., 2024; Momoh et al., 2023).

Between 2013 and 2015, a Lithuanian hacker orchestrated a highly sophisticated scheme that exploited the Facebook and Google reliance on vendor relationships (Akeiber, 2025). The hacker impersonated an executive from a legitimate, real-world vendor to build a sense of trust and credibility with employees. The scheme relied on convincing employees to authorize payments for non-existent services (Akeiber, 2025). Through these deceptive communications, the attacker successfully tricked the companies into transferring more than \$100 million (Akeiber, 2025).

Phishing is a prevalent initial attack vector used to trick employees into disclosing sensitive information, such as login credentials (Wheatley et al., 2021). Southern Cross can employ several strategies to combat this threat. First is the **Machine Learning (ML) & Automated Detection Tools**, these tools can detect phishing attempts in real-time by analyzing email content, behavior, and structural characteristics (Rodrigues et al., 2024). Some ML models have achieved a 92% detection rate with an average detection time of 0.15 seconds (Pimenta Rodrigues et al., 2024). However, attackers can use obfuscation techniques to hide malicious activities, and high false-alarm rates can lead security teams to ignore critical warnings. Second is the **Network Segmentation & Principle of Least Privilege**. It splits the infrastructure into isolated zones, which prevents attackers from moving laterally through the network if one employee's credentials are stolen (Enjam, 2020). The principle of least privilege ensures employees only have access to the specific data and systems required for their roles, limiting the scope of a potential breach (Shaikh et al., 2024). However,

implementing these controls can be highly complex, especially for large organizations with legacy systems or those that have grown through mergers and acquisitions, leading to inconsistent security laws and integrated weaknesses (Enjam, 2020).

3. Analysis of Current Southern Cross's Information Security Infrastructure

4. Recommended Alternative Security Design

5. Conclusion

From the perspective of Southern Cross, the three top risks regarding information security are Ransomware, Data Breaches & Unauthorized Access, and Phishing & Social Engineering Attacks. To address Ransomware, Southern Cross should implement Multi-Factor Authentication (MFA) and security education and training of their employees. To address data breaches and unauthorized access, Southern Cross should implement Encryption and intrusion detection and prevention system. To address Phishing and Social Engineering, Southern Cross should implement Machine Learning (ML) & Automated Detection Tools, and Network Segmentation & Principle of Least Privilege.

5. References

- Akeiber, H. J. (2025). The evolution of social engineering attacks: A cybersecurity engineering perspective. *Al-Rafidain Journal of Engineering Sciences*, 294–316.
- Alharbi, F. S. (2020). Dealing with data breaches amidst changes in technology. *International Journal of Computer Science and Security (IJCSS)*, 14(3), 108–115.
- AXA. *About us*. AXA. <https://www.axa.com/en/about-us>
- Bhadouria, A. S. (2022). Study of: Impact of malicious attacks and data breach on the growth and performance of the company and few of the world's biggest data breaches. *International Journal of Scientific and Research Publications*, 10(10), 1–11.

- Celestin, M., & Vanitha, N. (2022). Is your personal data safe? The cybersecurity crisis in insurance. *Indo American Journal of Multidisciplinary Research and Review*, 6(2), 192–199.
- Enjam, G. R. (2020). Ransomware Resilience and Recovery Planning for Insurance Infrastructure. *International Journal of AI, BigData, Computational and Management Studies*, 1(4), 29–37.
- Hossain, M. M., & Hong, Y. A. (2020). *Trends and characteristics of protected health information breaches in the United States*. 2019, 1081.
- Kheruddin, M. S., Zuber, M. A. E. M., & Radzai, M. M. M. (2024). Phishing attacks: Unraveling tactics, threats, and defenses in the cybersecurity landscape. *Authorea Preprints*.
- Ključnikov, A., Mura, L., & Sklenár, D. (2019). Information security management in SMEs: Factors of success. *Entrepreneurship and Sustainability Issues*, 6(4), 2081.
- Lehenchuk, S. F., Vygivska, I. M., & Hryhorevska, O. O. (2022). Protection of accounting information in the conditions of cyber security. *Проблеми Теорії Та Методології Бухгалтерського Обліку, Контролю і Аналізу*, (2(52)), 40–46.
[https://doi.org/10.26642/pbo-2022-2\(52\)-40-46](https://doi.org/10.26642/pbo-2022-2(52)-40-46)
- MacColl, J., Sullivan, J., Nurse, J. R. C., Mott, G., Turner, S., Cartwright, E., & Cartwright, A. (2023). *Cyber Insurance and the Ransomware Challenge*.
- Momoh, I., Adelaja, G., & Ejiwumi, G. (2023). *Analysis of the human factor in cybersecurity: Identifying and preventing social engineering attacks in financial institution*. IEEE.

- Mott, G., Turner, S., Nurse, J. R. C., MacColl, J., Sullivan, J., Cartwright, A., & Cartwright, E. (2023). Between a rock and a hard(ening) place: Cyber insurance in the ransomware era. *Computers & Security*, 128, 103162.
- Naz, A., Sarwar, M., Kaleem, M., Mushtaq, M. A., & Rashid, S. (2024). A comprehensive survey on social engineering-based attacks on social networks. *International Journal of Advanced and Applied Sciences*, 11(4), 139–154.
- Nemec Zlatolas, L., Welzer, T., & Lhotska, L. (2024). Data breaches in healthcare: Security mechanisms for attack mitigation. *Cluster Computing*, 27(7), 8639–8654.
- Olaniyan, J. (2024). Leveraging IT tools to safeguard customer data from social engineering threats. *International Journal of Research Publication and Reviews*, 5(12), 1564–1575.
- Pimenta Rodrigues, G. A., Marques Serrano, A. L., Lopes Espiñeira Lemos, A. N., Canedo, E. D., Mendonça, F. L. L. de, de Oliveira Albuquerque, R., & García Villalba, L. J. (2024). Understanding data breach from a global perspective: Incident visualization and data protection law review. *Data*, 9(2), 27.
- Raghupathi, W., Raghupathi, V., & Saharia, A. (2023). Analyzing health data breaches: A visual analytics approach. *AppliedMath*, 3(1), 175–199.
- Rodrigues, G. A. P., Serrano, A. L. M., Vergara, G. F., Albuquerque, R. de O., & Nze, G. D. A. (2024). Impact, compliance, and countermeasures in relation to data breaches in publicly traded US companies. *Future Internet*, 16(6), 201.
- Saleem, H., & Naveed, M. (2020). SoK: Anatomy of data breaches. *Proceedings on Privacy Enhancing Technologies*.

- Seh, A. H., Zarour, M., Alenezi, M., Sarkar, A. K., Agrawal, A., Kumar, R., & Ahmad Khan, R. (2020). Healthcare data breaches: Insights and implications. *Healthcare*, 8(2), 133.
- Shaikh, M. R., Ullah, R., Akbar, R., Savita, K., & Mandala, S. (2024). Fortifying against ransomware: Navigating cybersecurity risk management with a focus on ransomware insurance strategies. *International Journal of Academic Research in Business and Social Sciences*, 14(1), 1415–1430.
- Shankar, N., & Mohammed, Z. (2020). Surviving data breaches: A multiple case study analysis. *Journal of Comparative International Management*, 23(1), 35–54.
- Sharma, N., Oriaku, E. A., & Oriaku, N. (2020). Cost and effects of data breaches, precautions, and disclosure laws. *International Journal of Emerging Trends in Social Sciences*, 8(1), 33–41.
- Southern Cross Healthcare. *About us*. Southern Cross Healthcare.
<https://healthcare.southerncross.co.nz/about-us>
- Sullivan, J., & Nurse, J. R. C. (2021). *Cyber security incentives and the role of cyber insurance* (RUSI Emerging Insights Paper). Royal United Services Institute for Defence and Security Studies.
- Tao, H., Bhuiyan, M. Z. A., Rahman, M. A., Wang, G., Wang, T., Ahmed, Md. M., & Li, J. (2019). Economic perspective analysis of protecting big data security and privacy. *Future Generation Computer Systems*, 98, 660–671.
- Waelchli, S., & Walter, Y. (2025). Reducing the risk of social engineering attacks using SOAR measures in a real world environment: A case study. *Computers & Security*, 148, 104137.

Wang, P., D'Cruze, H., & Wood, D. (2019). Economic costs and impacts of business data breaches. *Issues in Information Systems*, 20(2).

Wheatley, S., Hofmann, A., & Sornette, D. (2021). Addressing insurance of data breach cyber risks in the catastrophe framework. *The Geneva Papers on Risk and Insurance-Issues and Practice*, 46(1), 53–78.

Yu, J., Yu, Y., Wang, X., Lin, Y., Yang, M., Qiao, Y., & Wang, F.-Y. (2024). The shadow of fraud: The emerging danger of AI-powered social engineering and its possible cure. *arXiv*, 2407.15912.